FUNDHUB LLC

INFORMATION SECURITY POLICY

Version 1.0 | Prepared November 2, 2026 | Policy owner: Chris Stanbridge

1. PURPOSE AND SCOPE

Fundhub protects the confidentiality, integrity, and availability of its customer, employee, contractor, and bank-connection data. This policy applies to people and devices with access to Fundhub production code, hosting, databases, logs, Plaid, and other service providers. The owner reviews it at least quarterly and after a material change or security incident. The operational runbook is docs/sops/RUNBOOK.md.

2. ACCESS AND AUTHENTICATION

Each person uses an individual account and the least access needed for their role. The owner reviews privileged access quarterly and removes or changes access when duties change or a person leaves. Production-critical provider accounts and staff payout-bank linking require a second sign-in factor. Recovery codes are stored in the account owner's password manager, not in source or shared messages. Client and affiliate bank linking requires a separate authenticator check and explicit consent before a Plaid Link token can be issued. An access requirement is recorded as implemented only after the live setting and sign-in path are verified.

3. DATA AND SECRETS

Secrets belong in provider-managed environment settings, never in source control. Plaid access tokens are encrypted before database storage. Production traffic uses HTTPS. Data received from Plaid is stored in Fundhub's Supabase database, whose published policy covers database data and backups with AES-256; the production database hostname was verified as a Supabase pooler. Identified downstream processors of Plaid-derived summaries (Twilio, Resend, Anthropic, Inngest, and Netlify logs) also publish encryption-at-rest commitments. Recipient mailboxes and phones are outside Fundhub's storage boundary. Access to consumer data is role scoped and logged where supported. Consent for bank linking records the exact text, scope, version, account, target, and time, and is retained for review subject to an explicit erasure request.

4. CHANGE AND VULNERABILITY MANAGEMENT

Code changes receive automated lint, type checks, focused tests, independent review for production-risk changes, and protected release checks. Production dependencies and assets are scanned on a recurring schedule. A finding is assigned an owner and due date; critical findings target repair within 7 days and high findings within 30 days, or sooner if a provider deadline applies. A fix is rescanned. Employee and contractor devices with production access belong in the scan inventory and require current protection. Missing device evidence is tracked as an open gap, not a completed control.

5. INCIDENT RESPONSE

The first responder records the time and affected system, limits exposure by suspending the credential or session, and preserves relevant logs. The owner determines affected data and people, rotates exposed keys, coordinates provider support, and records containment, recovery, notifications, and follow-up actions. Restore service through the tested release and backup procedures. The owner reviews the incident and updates controls. Availability incident steps and emergency contacts are in docs/sops/RUNBOOK.md.

6. RETENTION AND DELETION

Keep consumer data only while needed for the service and applicable obligations. Review each data class and retention period quarterly. A monthly job records count-only review receipts and does not delete customer records. Actual deletion requires signed retention periods, an owner/admin session with recently verified MFA, a dry-run review, and a durable receipt in the same transaction as the change. Deletion is manual until an approved schedule is implemented and verified. An individual erasure request follows the separate erasure procedure and preserves only records that must lawfully remain.

7. VENDORS AND EVIDENCE

The owner maintains a list of providers with access to sensitive data and reviews their access and security evidence. Control claims for Plaid or any other reviewer reflect observed production settings and retained test or provider receipts. Source code or this policy alone does not prove that a setting is active in production.

IMPLEMENTATION STATUS AT PREPARATION

The personal GitHub account that owns the repository completed authenticator enrollment, and its account security page showed MFA enabled on November 2, 2026. Netlify account MFA was enabled and verified on its security page the same day. Staff payout-bank MFA was deployed but had not completed a live sign-in proof. Client and affiliate bank-link MFA, monthly review receipts, and recurring dependency scan were in the release branch and were not live. MFA coverage for other critical provider accounts, device scan inventory, project backup configuration, recipient handling, approved retention periods, and a real deletion receipt were still open. Public fundhub.ai accepted TLS 1.2 and refused TLS 1.1. The open items must be checked again before answering Plaid's

questionnaire.

PROVIDER EVIDENCE REVIEWED NOVEMBER 2, 2026
Supabase: https://supabase.com/legal/privacy-resources/data-residency-and-transfers-faq
Twilio: https://www.twilio.com/en-us/legal/security-overview
Resend: https://resend.com/security
Anthropic: https://trust.anthropic.com/faq
Inngest: https://www.inngest.com/docs/platform-and-operations/cloud-architecture-and-security
Netlify: https://docs.netlify.com/manage/security/overview/